

ETHOS NETWORK · SECURITY REVIEW

Ethos Network

WHUF Transfer Lock.

A security review of WHUF Transfer Lock.

CLIENT	PROJECT	AUDITORS	AUDIT WINDOW	FINAL REPORT
Ethos Network	WHUF Transfer Lock	Andreas Zottl, Zdravko Hristov, Vlad Zotov, Michael Lett, Ferran Celades	September 25 – September 25, 2026	September 25, 2026

§ 00

Contents.

15 pages: overview, confidence ranking, scope, 5 findings, disclaimer, and about Guardian.

§ 01	Overview	P. 03
§ 02	Confidence Ranking	P. 04
§ 03	Scope & Classifications	P. 05
	Files in Scope	P. 06
§ 04	Findings	P. 07
	Main Review · 5 findings	P. 08
§ 05	Disclaimer	P. 14
§ 06	About Guardian	P. 15

§ 01

Overview.

Guardian reviewed WHUF Transfer Lock across 2 review rounds. The final report includes 5 Informational findings.

AUDIT FIRM	REPOSITORY
Guardian	https://github.com/trust-ethos/ethos-protocol
CLIENT	METHODOLOGY
Ethos Network	Smart contract · Manual · Main Review · Remediation Review
PROJECT	MAIN REVIEW COMMIT
WHUF Transfer Lock	92f8e0424235
PREPARED BY	REMEDICATION REVIEW COMMIT
Andreas Zottl, Zdravko Hristov, Vlad Zotov, Michael Lett, Ferran Celades	92f8e0424235
AUDIT WINDOW	
September 25 – September 25, 2026	
FINAL REPORT	
September 25, 2026	

1.1 Confidence Ranking

5 / 5

Very High Confidence

Guardian assigns a Confidence Ranking of 5 out of 5, combining finding severity, remediation outcome, and the reviewer’s assessment of latent risk. The full scale is on the next page.

1	2	3	4	5
VERY LOW CONFIDENCE	LOW CONFIDENCE	MODERATE CONFIDENCE	HIGH CONFIDENCE	VERY HIGH CONFIDENCE

1.2 Findings at a Glance

SEVERITY	TOTAL	PENDING	ACK	PARTIAL	RESOLVED
Critical	0	0	0	0	0
High	0	0	0	0	0
Medium	0	0	0	0	0
Low	0	0	0	0	0
Informational	5	0	5	0	0
All severities	5	0	5	0	0

§ 02

Confidence Ranking.

Guardian assigns a project-level confidence score using the scale below. The ranking combines finding severity, remediation outcome, and the reviewer's assessment of latent risk.

CONFIDENCE RANKING	DEFINITION AND RECOMMENDATION	RISK PROFILE
5 Very High Confidence ASSIGNED	Codebase is mature, clean, and secure. No High or Critical vulnerabilities were found. Follows modern best practices with high test coverage and thoughtful design. Recommendation: code is highly secure at time of audit.	0 High/Critical findings and few Low/Medium severity findings.
4 High Confidence	Code is clean, well-structured, and adheres to best practices. Design patterns are sound and test coverage is strong. Recommendation: suitable for deployment after remediations; consider periodic review with changes.	0-1 High/Critical findings per engagement week and little to no Medium severity findings.
3 Moderate Confidence	Code is functional but shows gaps in defensive programming or test coverage. Recommendation: remediate the findings and re-review the changes before deployment.	Some High/Critical findings, with various Medium severity findings.
2 Low Confidence	Recurring issues suggest systemic gaps rather than isolated mistakes. Recommendation: remediate, then commission a follow-up review at a frozen commit.	Over 6 High and Critical findings across the engagement.
1 Very Low Confidence	The volume and severity of findings indicate the codebase is not ready for production. Recommendation: substantial rework, then a full re-review.	Over 12 High and Critical findings across the engagement.

§ 03

Scope & Classifications.

Guardian reviewed WHUF Transfer Lock in <https://github.com/trust-ethos/ethos-protocol>. The scope includes 70 source lines across 8 files.

3.1 Severity Matrix

	IMP · HIGH	IMP · MED	IMP · LOW
LIK · HIGH	Critical	High	Medium
LIK · MED	High	Medium	Low
LIK · LOW	Medium	Low	Low

IMPACT · HIGH

Significant loss of assets, harm to a group of users, or core protocol functionality is disrupted.

IMPACT · MEDIUM

Small amount of funds can be lost, or ancillary functionality is affected. Users may experience reduced or delayed receipt.

IMPACT · LOW

Unexpected behavior in some functionality that is notable but does not meet the criteria for higher severity.

LIKELIHOOD · HIGH

Possible with reasonable assumptions that mimic on-chain conditions; cost is low compared to amount gained.

LIKELIHOOD · MEDIUM

Possible only in uncommon cases or requires a large amount of capital relative to disruption caused.

LIKELIHOOD · LOW

Unlikely to ever occur in production.

Files in Scope.

FILE	NSLOC	TOTAL
src/errors/WhuffieErrors.sol	0	19
src/EthosWhuffie.sol	18	174
src/interfaces/IWhuffieLockList.sol	3	10
src/WhuffieLockList.sol	14	44
src/errors/WhuffieErrors.sol	0	19
src/EthosWhuffie.sol	18	174
src/interfaces/IWhuffieLockList.sol	3	10
src/WhuffieLockList.sol	14	44

§ 04

Findings.

Grouped by round. Visible IDs reset by severity within each round, so a finding is named the same way in the report as it was in the channel it was written in. Each finding's status is on its own page.

ID	TITLE	CATEGORY	SEVERITY	PAGE
MAIN REVIEW				
I-01	Deployment tooling omits the new lock-list constructor argument	Configuration	INFORMATIONAL	p. 8
I-02	Scheduled unlock observability is lazy and its timestamp depends on the trigger	Events	INFORMATIONAL	p. 9
I-03	Market and Rewards documentation does not respond to actual behavior	Documentation	INFORMATIONAL	p. 10
I-04	TransfersUnlocked owner parameter documentation is ambiguous	Documentation	INFORMATIONAL	p. 12
I-05	UNLOCK_AT documentation incorrectly requires a balance change	Documentation	INFORMATIONAL	p. 13
REMEDIATION REVIEW				

INFORMATIONAL I-01

ACKNOWLEDGED

Deployment tooling omits the new lock-list constructor argument

CATEGORY	Configuration
LOCATION	https://github.com/GuardianOrg/mirror-trust-ethos-ethos-protocol-5ccc445c0c31d01cfe73a411d1e10983/blob/92f8e0424235b228246451b6c0d53142bad458fd/src/EthosWhuffie.sol#L74-L82
REVIEW	Main Review

— DESCRIPTION

The change makes every EthosWhuffie implementation deployment require an IWhuffieLockList constructor argument. The supplied `deployUpgradeable()` path still uses `deployViaCreate2(signer, factory, [], salt)` for deterministic deployment and `factory.deploy()` for the legacy path, so neither provides that argument. The `ethosWhuffie` configuration supplies only the three proxy initializer arguments, and the market-stack deployment sequence does not deploy a `WhuffieLockList` first. The compiled `EthosWhuffie` artifact confirms one mandatory constructor input. Fresh proxy deployments and implementation upgrades through the supplied flow cannot encode or deploy this implementation. Solidity fixtures pass the list directly and miss the mismatch. This audit mirror omits `package.json`, `deploy.ts`, and `abi/index.ts`, so the TypeScript path could not be executed end to end here; the code and compiled ABI establish the argument mismatch. Downstream code: `scripts/deploy-contract.ts:944-951` and `scripts/ops/deploy-market-stack.ts:22-46`.

— RECOMMENDATION

Be aware.

— RESOLUTION

Status: Acknowledged.

INFORMATIONAL I-02

ACKNOWLEDGED

Scheduled unlock observability is lazy and its timestamp depends on the trigger

CATEGORY	Events
LOCATION	https://github.com/GuardianOrg/mirror-trust-ethos-ethos-protocol-5ccc445c0c31d01cfe73a411d1e10983/blob/92f8e0424235b228246451b6c0d53142bad458fd/src/EthosWhuffie.sol#L141-L161
REVIEW	Main Review

DESCRIPTION

At UNLOCK_AT, the launch lock no longer prevents a balance change, but transfersUnlocked remains false and no TransfersUnlocked event is emitted until a successful balance change lazily updates the flag. That automatic path emits UNLOCK_AT even if the triggering transaction occurs later. The owner may instead call unlockTransfers() after UNLOCK_AT before any balance change; that path emits the later block.timestamp. Thus the same scheduled release can produce either the deadline or a later transaction time depending on which post-deadline transaction arrives first. During the gap, the public flag is false even though a transfer would succeed. The event NatSpec calls its field the block timestamp when transfers were unlocked, leaving its meaning inconsistent for frontends and monitors. On-chain transfer enforcement remains correct. Prior I-30 concerned a missing manual-unlock event; that was fixed before this scheduled path was introduced.

RECOMMENDATION

Either acknowledge the finding or apply one of the proposed fixes:

- emit `block.timestamp` at both places
- emit `min(block.timestamp, UNLOCK_AT)` in `unlockTransfers()`

RESOLUTION

Status: Acknowledged.

INFORMATIONAL I-03

ACKNOWLEDGED

Market and Rewards documentation does not respond to actual behavior

CATEGORY	Documentation
LOCATION	https://github.com/GuardianOrg/mirror-trust-ethos-ethos-protocol-5ccc445c0c31d01cfe73a411d1e10983/blob/92f8e0424235b228246451b6c0d53142bad458fd/AUDIT_FAQ.md
REVIEW	Main Review

DESCRIPTION

The documentation states that Market trading and Rewards claims are not expected to work for locked accounts because `EthosMarket` and `EthosRewards` are included in `WhuffieLockList`. However, `_update()` applies the restriction based only on whether the WHUF sender is locked, making the actual behavior dependent on the direction of each transfer.

```
```solidity
Which WHUF flows should work before transfers unlock?
```

The lock is per account, not global. Accounts on `WhuffieLockList` (pre-launch mint recipients other than Treasury, and Ethos proxies other than `EthosVouchV2` and `EthosReview`) cannot send WHUF before `UNLOCK_AT` except into or out of `EthosVouchV2`, or as an `EthosReview` fee pull. Accounts not on the list, including market makers funded by Treasury, transfer freely. Market trading and Rewards claims are not expected to work for locked accounts before `UNLOCK_AT` because `EthosMarket` and `EthosRewards` are themselves on the list.

When buying from the Market, the buyer is the WHUF sender. Purchases therefore fail for locked buyers but remain available to buyers who are not included in `WhuffieLockList`, regardless of the Market's locked status. When selling, `EthosMarket` is the WHUF sender, so the payout fails while the Market remains locked even if the seller is not locked.

Similarly, `EthosRewards` is the WHUF sender during `claim()`. Consequently, Rewards claims fail while `EthosRewards` remains locked even when the claimant is not included in `WhuffieLockList`.

**I - 03**      Market and Rewards documentation does not respond to actual behavior**CONTINUED**

Therefore, before the global transfer unlock, an unlocked user can buy a Market position but cannot sell it or claim accrued rewards.

**— RECOMMENDATION**

Revisit whether this is the intended behavior and if yes, fix the documentation. Otherwise, apply the needed changes

**— RESOLUTION**

Status: Acknowledged.

## INFORMATIONAL I-04

ACKNOWLEDGED

# TransfersUnlocked owner parameter documentation is ambiguous

CATEGORY	Documentation
LOCATION	<a href="https://github.com/GuardianOrg/mirror-trust-ethos-ethos-protocol-5ccc445c0c31d01cfe73a411d1e10983/blob/92f8e0424235b228246451b6c0d53142bad458fd/src/EthosWhuffie.sol#L58-L61">https://github.com/GuardianOrg/mirror-trust-ethos-ethos-protocol-5ccc445c0c31d01cfe73a411d1e10983/blob/92f8e0424235b228246451b6c0d53142bad458fd/src/EthosWhuffie.sol#L58-L61</a>
REVIEW	Main Review

## DESCRIPTION

The `owner` parameter is described as "the token owner," which could mean either a WHUF holder or the `EthosWhuffie` contract owner. The emitted value represents the contract owner.

## RECOMMENDATION

Describe `owner` as "the `EthosWhuffie` contract owner."

## RESOLUTION

Status: Acknowledged.

INFORMATIONAL I-05

ACKNOWLEDGED

# UNLOCK\_AT documentation incorrectly requires a balance change

CATEGORY Documentation

LOCATION <https://github.com/GuardianOrg/mirror-trust-ethos-ethos-protocol-5ccc445c0c31d01cfe73a411d1e10983/blob/92f8e0424235b228246451b6c0d53142bad458fd/src/EthosWhuffie.sol#L48-L49>

REVIEW Main Review

## DESCRIPTION

The comment states that the first balance change after `UNLOCK_AT` triggers unlocking. However, zero-value transfers, mints, and burns also invoke `_update()` and unlock transfers without changing any balance.

## RECOMMENDATION

Replace "balance change" with "transfer, mint, or burn operation."

## RESOLUTION

Status: Acknowledged.

## § 05

# Disclaimer.

This report is not, nor should be considered, an "endorsement" or "disapproval" of any particular project or team. This report is not, nor should be considered, an indication of the economics or value of any "product" or "asset" created by any team or project that contracts Guardian to perform a security assessment. This report does not provide any warranty or guarantee regarding the absolute bug-free nature of the technology analyzed, nor do they provide any indication of the technologies proprietors, business, business model or legal compliance.

This report should not be used in any way to make decisions around investment or involvement with any particular project. This report in no way provides investment advice, nor should be leveraged as investment advice of any sort. This report represents an extensive assessing process intending to help our customers increase the quality of their code while reducing the high level of risk presented by cryptographic tokens and blockchain technology.

Blockchain technology and cryptographic assets present a high level of ongoing risk. Guardian's position is that each company and individual are responsible for their own due diligence and continuous security. Guardian's goal is to help reduce the attack vectors and the high level of variance associated with utilizing new and consistently changing technologies, and in no way claims any guarantee of security or functionality of the technology we agree to analyze.

The assessment services provided by Guardian is subject to dependencies and under continuing development. You agree that your access and/or use, including but not limited to any services, reports, and materials, will be at your sole risk on an as-is, where-is, and as-available basis.

Cryptographic tokens are emergent technologies and carry with them high levels of technical risk and uncertainty. The assessment reports could include false positives, false negatives, and other unpredictable results. The services may access, and depend upon, multiple layers of third-parties.

Notice that smart contracts deployed on the blockchain are not resistant from internal/external exploit. Notice that active smart contract owner privileges constitute an elevated impact to any smart contract's safety and security. Therefore, Guardian does not guarantee the explicit security of the audited smart contract, regardless of the verdict.

§ 06

# About Guardian.

Guardian is a smart contract security firm. Every engagement is worked by two independent teams competing on the same scope, each with its own tooling and methods, so no single reviewer's blind spot survives.

**\$45B+**DIGITAL ASSETS UNDER  
REVIEW**200+**

ENGAGEMENTS COMPLETED

**500+**CRITICAL & HIGH FINDINGS  
REPORTED

Reach us at [audits@guardianaudits.com](mailto:audits@guardianaudits.com).